



REPORT

ผลวิเคราะห์ Credential Leak เดือนพฤศจิกายน ปี 2024



ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (ศปช.)
สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ

Email: thaicert@ncsa.or.th

Website:

<https://www.ncsa.or.th>

<https://www.thaicert.or.th>

120 หมู่ 3 อาคารรัฐประศาสนภักดี (อาคารบี) ชั้น 7 ศูนย์ราชการเฉลิมพระเกียรติ 80 พรรษา
5 ธันวาคม 2560 ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ 10210



คำนำ

รายงานผลการวิเคราะห์ Credential Leak เดือนพฤศจิกายน ปี 2567 นี้จัดทำขึ้นเพื่อให้ข้อมูลเชิงลึกเกี่ยวกับสถิติ Credential Leak ที่เกิดขึ้นในช่วงเดือนพฤศจิกายน โดยการวิเคราะห์เน้นแสดงประเภทของหน่วยงานที่ได้รับผลกระทบ ซึ่งประกอบด้วยหน่วยงานควบคุมหรือกำกับดูแล (Regulators) หน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII) และหน่วยงานรัฐบาล (GOV) รวมถึงจำนวนเหตุการณ์ (Event) ที่เกิดขึ้นในเดือนดังกล่าว นอกจากนี้ รายงานยังได้นำเสนอแนวทางการป้องกันและรับมือที่สามารถนำไปใช้ได้จริง เพื่อเสริมสร้างความปลอดภัยทางข้อมูล ทั้งในระดับองค์กรและบุคคลทั่วไป พร้อมทั้งช่วยเตรียมความพร้อมในการลดความเสี่ยงจากภัยคุกคามทางไซเบอร์ที่พัฒนาและเปลี่ยนแปลงอย่างต่อเนื่อง

รายงานฉบับนี้มีเป้าหมายเพื่อช่วยให้ผู้อ่านเข้าใจภาพรวมของสถานการณ์ Credential Leak ได้ชัดเจนมากขึ้น และสามารถนำข้อมูลที่ได้ไปปรับใช้เพื่อ ยกกระดับระบบป้องกันและสร้างความมั่นคงทางไซเบอร์ได้อย่างมีประสิทธิภาพมากขึ้นในอนาคต

สารบัญ

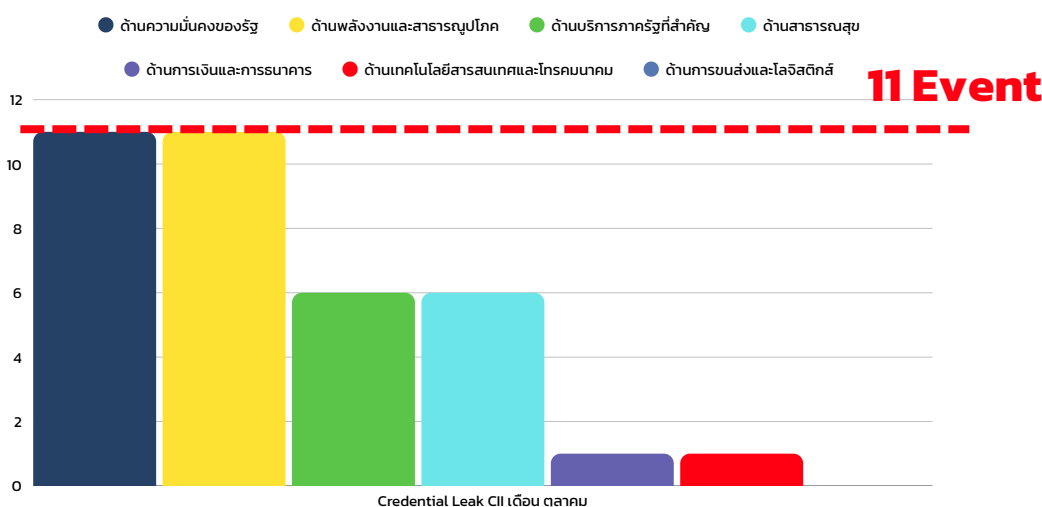
ภาพรวม Credential Leak เดือนพฤศจิกายน ปี 2024 ของหน่วยงานควบคุมหรือกำกับดูแล (Regulators).....	1
ภาพรวม Credential Leak เดือนพฤศจิกายน ปี 2024 ของหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII).....	2
ภาพรวม Credential Leak เดือนพฤศจิกายน ปี 2024 ของหน่วยงานรัฐบาล (GOV).....	3
แนวทางการป้องกันและรับมือ.....	4



ภาพรวม Credential Leak เดือนพฤศจิกายน ปี 2024 ของหน่วยงานควบคุมหรือกำกับดูแล (Regulators)

ในเดือนพฤศจิกายน ปี 2024 ของหน่วยงานควบคุมหรือกำกับดูแล (Regulators) แสดงให้เห็นถึงความเสี่ยงที่ยังคงมีอยู่ โดยเฉพาะในหน่วยงานด้านความมั่นคงของรัฐและด้านพลังงานและสาธารณูปโภค ซึ่งพบ Credential Leak สูงที่สุด จำนวน 11 เหตุการณ์ในแต่ละด้าน รองลงมาคือด้านบริการภาครัฐที่สำคัญ และด้านสาธารณสุข ด้านละ 6 เหตุการณ์ ขณะที่ด้านการเงินและการธนาคาร และด้านเทคโนโลยีสารสนเทศและโทรคมนาคม พบด้านละ 1 เหตุการณ์ และด้านการขนส่งและโลจิสติกส์ไม่มีการรายงานเหตุการณ์ในเดือนนี้

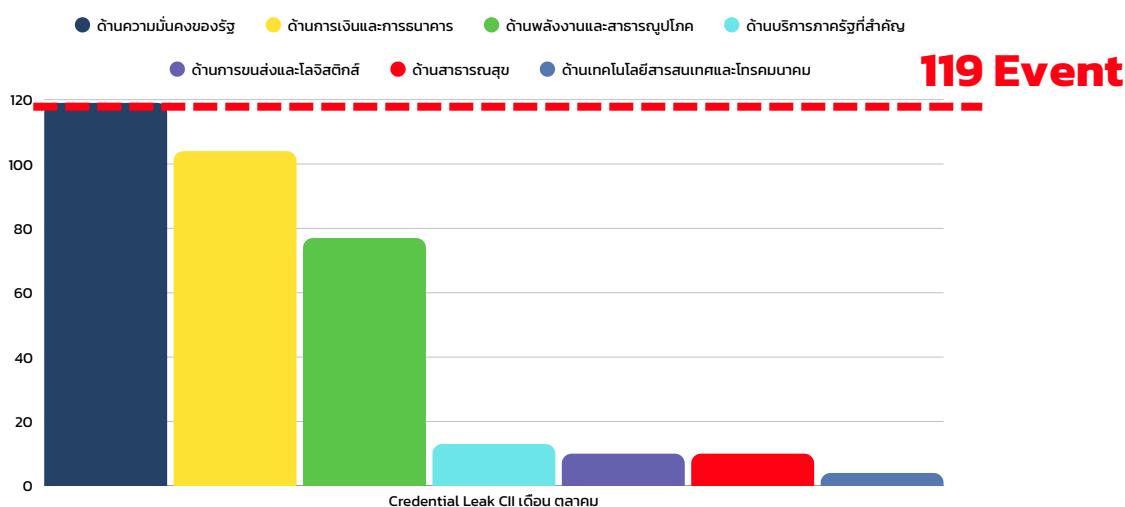
ประเภทหน่วยงาน	Event
ด้านความมั่นคงของรัฐ	11
ด้านพลังงานและสาธารณูปโภค	11
ด้านบริการภาครัฐที่สำคัญ	6
ด้านสาธารณสุข	6
ด้านการเงินและการธนาคาร	1
ด้านเทคโนโลยีสารสนเทศและโทรคมนาคม	1
ด้านการขนส่งและโลจิสติกส์	0



ภาพรวม Credential Leak เดือนพฤศจิกายน ปี 2024 ของหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII)

ในเดือนพฤศจิกายน ปี 2024 ของหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศ (CII) แสดงให้เห็นถึงความเสี่ยงที่สำคัญ โดยเฉพาะในหน่วยงานด้านความมั่นคงของรัฐที่พบ Credential Leak สูงสุดถึง 119 เหตุการณ์ รองลงมาคือด้านการเงินและการธนาคาร 104 เหตุการณ์ และด้านพลังงานและสาธารณูปโภค 77 เหตุการณ์ ขณะที่ด้านบริการภาครัฐที่สำคัญมี 13 เหตุการณ์ ด้านการขนส่งและโลจิสติกส์และด้านสาธารณสุข ด้านละ 10 เหตุการณ์ และด้านเทคโนโลยีสารสนเทศและโทรคมนาคม 4 เหตุการณ์

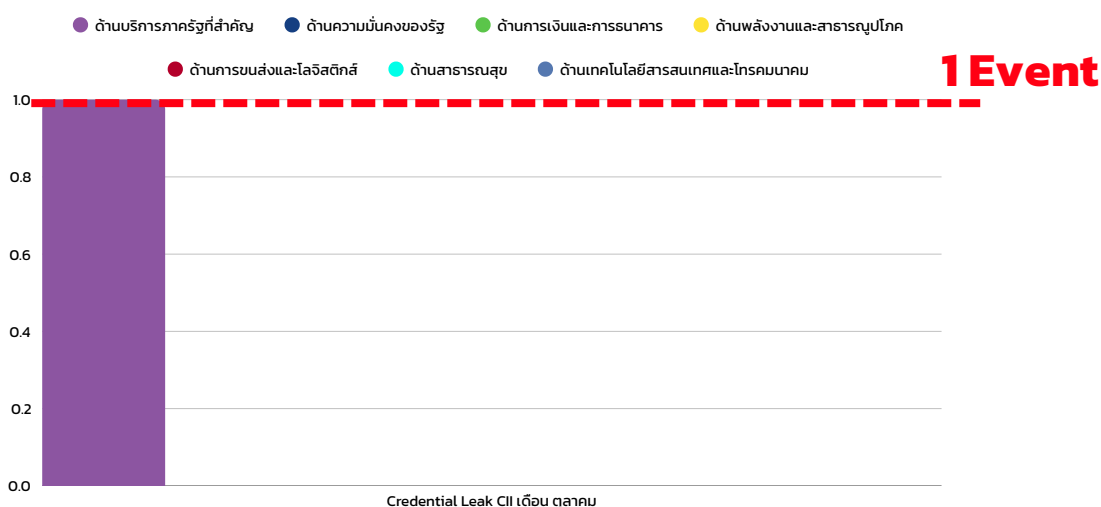
ประเภทหน่วยงาน	Event
ด้านความมั่นคงของรัฐ	119
ด้านการเงินและการธนาคาร	104
ด้านพลังงานและสาธารณูปโภค	77
ด้านบริการภาครัฐที่สำคัญ	13
ด้านการขนส่งและโลจิสติกส์	10
ด้านสาธารณสุข	10
ด้านเทคโนโลยีสารสนเทศและโทรคมนาคม	4



ภาพรวม Credential Leak เดือนพฤศจิกายน ปี 2024 ของหน่วยงานรัฐบาล (GOV)

ในเดือนพฤศจิกายน ปี 2024 สถิติการพบ Credential Leak ในหน่วยงานรัฐบาล (GOV) อยู่ในระดับต่ำมาก โดยพบเพียง 1 เหตุการณ์ในด้านบริการภาครัฐที่สำคัญ ขณะที่ด้านความมั่นคงของรัฐ ด้านการเงินและการธนาคาร ด้านพลังงานและสาธารณูปโภค ด้านการขนส่งและโลจิสติกส์ ด้านสาธารณสุข และด้านเทคโนโลยีสารสนเทศและโทรคมนาคม ไม่มีรายงานการเกิด Credential Leak

ประเภทหน่วยงาน	Event
ด้านบริการภาครัฐที่สำคัญ	1
ด้านความมั่นคงของรัฐ	0
ด้านการเงินและการธนาคาร	0
ด้านพลังงานและสาธารณูปโภค	0
ด้านการขนส่งและโลจิสติกส์	0
ด้านสาธารณสุข	0
ด้านเทคโนโลยีสารสนเทศและโทรคมนาคม	0



แนวทางการป้องกันและรับมือ Credential Leak

1.การบังคับใช้การยืนยันตัวตนหลายปัจจัย (Multi-Factor Authentication - MFA)

- การยืนยันตัวตนหลายปัจจัยช่วยลดความเสี่ยงจากการที่รหัสผ่านรั่วไหล แม้ผู้โจมตีจะได้ข้อมูลไปก็ไม่สามารถเข้าสู่ระบบได้หากไม่มีขั้นตอนการยืนยันเพิ่มเติม

2.การเข้ารหัสข้อมูล (Credential Encryption)

- รหัสผ่านและข้อมูลที่จัดเก็บในฐานข้อมูลควรมีการเข้ารหัสเสมอ เพื่อลดความเสี่ยงจากการเกิดข้อมูลหลุดแล้วถูกนำไปใช้งานได้ทันที
- การใช้การแฮชแบบ Salted Hash ช่วยให้การถอดรหัสทำได้ยากขึ้น แม้ว่าผู้โจมตีจะได้ข้อมูลแฮชไป

3.การตั้งรหัสผ่านที่แข็งแกร่ง (Password Policy)

- บังคับให้ผู้ใช้ตั้งรหัสผ่านที่ซับซ้อน เช่น รหัสผ่านควรประกอบด้วยตัวอักษรใหญ่-เล็ก ตัวเลข และสัญลักษณ์ รวมถึงมีความยาวอย่างน้อย 12 ตัวอักษร
- หลีกเลี่ยงการใช้รหัสผ่านเดิมซ้ำกับหลายๆ บัญชีหรือตั้งรหัสผ่านที่ง่ายเกินไป ซึ่งเป็นสาเหตุที่ทำให้ถูกโจมตีด้วยวิธี Brute Force

4.ระบบการจัดการรหัสผ่าน (Password Management System)

- ควรใช้ระบบจัดการรหัสผ่านที่มีความปลอดภัยและเป็นไปตามมาตรฐาน เช่น Password Vault หรือ Password Manager เพื่อจัดเก็บข้อมูลอย่างปลอดภัยและลดการใช้รหัสผ่านที่ซ้ำกัน

5.การปิดกั้นการเข้าถึงโดยไม่ได้รับอนุญาต (Access Control)

- ใช้การควบคุมสิทธิ์การเข้าถึงในทุกระบบ และกำหนดสิทธิ์ที่เหมาะสมกับหน้าที่ของแต่ละผู้ใช้งาน (Least Privilege) เพื่อจำกัดการเข้าถึงเฉพาะผู้ที่จำเป็นเท่านั้น
- ติดตามและปรับปรุงสิทธิ์ของผู้ใช้อย่างสม่ำเสมอ เพื่อลดความเสี่ยงที่ข้อมูลจะรั่วไหลจากสิทธิ์เกินความจำเป็น

6.การตรวจสอบบันทึกเหตุการณ์และระบบแจ้งเตือน (Central Logging & Monitoring)

- จัดเก็บและตรวจสอบบันทึกเหตุการณ์ (Logs) โดยเฉพาะบันทึกการเข้าสู่ระบบผิดพลาดหรือพยายามเข้าถึงระบบจาก IP ที่ไม่น่าไว้วางใจ
- การตั้งค่าแจ้งเตือนเพื่อแจ้งเตือนผู้ดูแลระบบเมื่อตรวจพบกิจกรรมที่น่าสงสัยจะช่วยให้สามารถตอบสนองได้อย่างรวดเร็ว

7.การฝึกอบรมด้าน Cyber Security Awareness

- สร้างความตระหนักรู้ให้กับพนักงานเพื่อหลีกเลี่ยงพฤติกรรมที่เสี่ยงต่อการรั่วไหลของข้อมูล เช่น หลีกเลี่ยงการบันทึกหรือการคลิกลิงก์แปลกปลอมที่อาจนำไปสู่การถูกขโมยรหัสผ่าน

8.การใช้การตรวจสอบความปลอดภัยอย่างต่อเนื่อง (Continuous Security Testing)

- ทำการทดสอบความปลอดภัย เช่น การทดสอบการเจาะระบบ (Penetration Testing) และการประเมินช่องโหว่ (Vulnerability Assessment) เป็นระยะ ๆ เพื่อให้มั่นใจว่าไม่มีช่องโหว่ที่สามารถนำไปสู่การรั่วไหลของข้อมูล

แนวทางการป้องกันและรับมือ Credential Leak

9.การจัดการและตรวจสอบบัญชีผู้ใช้ในฐานข้อมูล

- ลบบัญชีผู้ใช้ที่ไม่ได้ใช้งานและทำการตรวจสอบสิทธิ์การเข้าถึงฐานข้อมูลอย่างสม่ำเสมอ
- กำหนดสิทธิ์การเข้าถึงฐานข้อมูลให้เฉพาะโปรแกรมที่เกี่ยวข้องและอุปกรณ์ที่ได้รับอนุญาตเท่านั้น

10.การตอบสนองเมื่อเกิด Credential Leak

- เปลี่ยนรหัสผ่าน: รีเซ็ตรหัสผ่านที่อาจได้รับผลกระทบทันที และบังคับให้ผู้ใช้ทั้งหมดตั้งรหัสผ่านใหม่
- ตรวจสอบและบันทึกเหตุการณ์: วิเคราะห์บันทึกเหตุการณ์ที่เกี่ยวข้องกับการรั่วไหลของข้อมูลเพื่อระบุวิธีการโจมตี และเก็บหลักฐานเพื่อใช้ในการตรวจสอบหรือรายงานเหตุการณ์
- แจ้งเตือนหน่วยงานที่เกี่ยวข้อง: หากมีข้อมูลส่วนบุคคลรั่วไหล ควรแจ้งให้หน่วยงานที่เกี่ยวข้องทราบตามกฎหมายและข้อบังคับ



References

- Threat Intelligence ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์
- Recorded Future (TI)



ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (ศปช.)
สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ

Email: thaicert@ncsa.or.th

Webste:

<https://www.ncsa.or.th>

<https://www.thaicert.or.th>

120 หมู่ 3 อาคารรัฐประศาสนภักดี (อาคารบี) ชั้น 7 ศูนย์ราชการเฉลิมพระเกียรติ 80 พรรษา
5 ธันวาคม 2560 ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ 10210

